



Ghost Telephonist

Impersonates You Through LTE CSFB

Yuwei ZHENG, Lin HUANG, Qing YANG, Haoqi SHAN, Jun LI

UnicornTeam, 360 Technology
July 30, 2017



Who We Are



- 360 Technology is a leading Internet security company in China. Our core products are anti-virus security software for PC and cellphones.



- UnicornTeam (<https://unicorn.360.com/>) was built in 2014. This is a group that focuses on the security issues in many kinds of wireless telecommunication systems.



- Highlighted works of UnicornTeam include:
 - Low-cost GPS spoofing research (DEFCON 23)
 - LTE redirection attack (DEFCON 24)
 - Attack on power line communication (BlackHat USA 2016)

Voice Solutions in LTE Network

- VoLTE
 - Voice over LTE, based on IP Multimedia Subsystem (IMS)
 - Final target of network evolution
- CSFB
 - Circuit Switched Fallback: switch from 4G to 3G or 2G when taking voice call
- SV-LTE
 - Simultaneous Voice and LTE
 - Higher price and rapid power consumption on terminal

Occasional Discovery

- When we used OsmocomBB as cellphone to access GSM network, we met a difficulty. During debugging the problem, we occasionally found a fake paging response can build the connection to network.

Normal 2G Call vs. CSFB

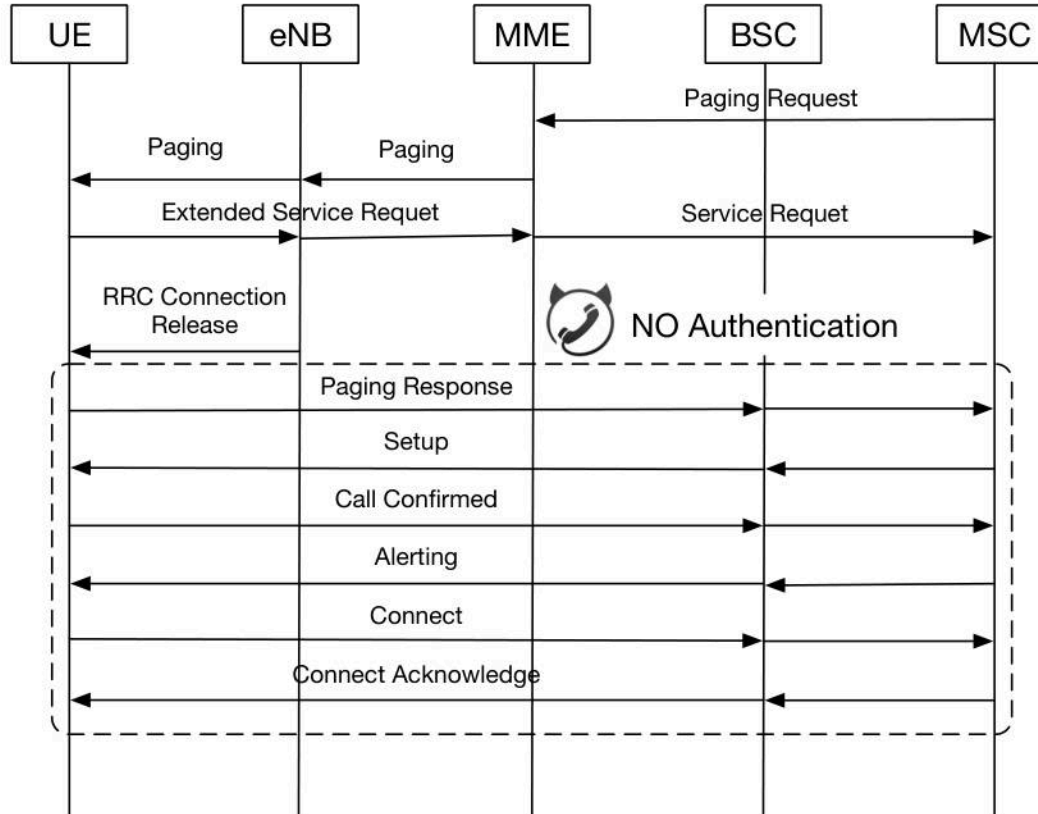
15:59:11.464	RR/CCCH/Paging Request Type 1
15:59:11.937	RR/CCCH/Paging Request Type 1
15:59:11.939	RR/Paging Response
15:59:12.014	RR/CCCH/Paging Request Type 1
15:59:12.042	RR/CCCH/Paging Request Type 1
15:59:12.060	RR/CCCH/Paging Request Type 1
15:59:12.092	RR/BCCH/System Information Type 4
15:59:12.111	RR/CCCH/Immediate Assignment
15:59:12.120	RR/DCCH/Paging Response
15:59:12.291	RR/SACCH/System Information Type 5
15:59:12.452	RR/DCCH/Classmark Change
15:59:12.453	RR/DCCH/GPRS Suspension Request
15:59:12.762	RR/SACCH/System Information Type 5
15:59:12.827	RR/SACCH/M Measurement Report
15:59:12.923	MM/Authentication Request
15:59:13.053	MM/Authentication Response
15:59:13.232	RR/SACCH/System Information Type 6
15:59:13.297	RR/SACCH/M Measurement
15:59:13.394	CC/Setup
15:59:13.403	CC/Call Confirmed
15:59:13.703	RR/SACCH/System Inform

When we analyze the signaling flow of CSFB, we were surprised to find that there is no authentication step.

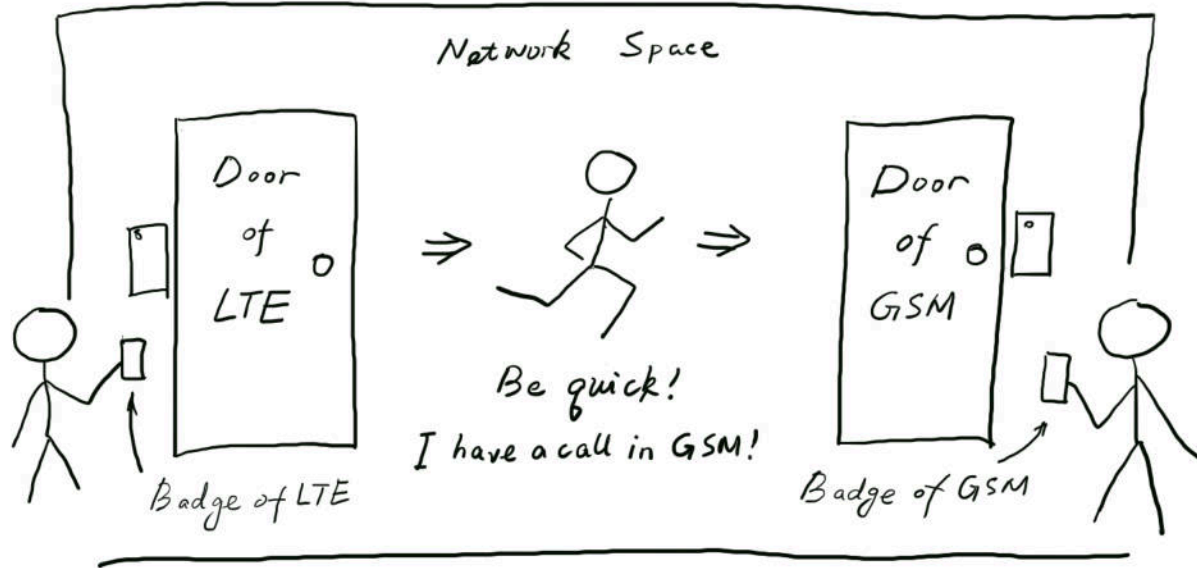
In normal 2G call, AKA does exist for every call.

16:12:49.063	RRC/DCCH/ueCapabilityInformation
16:12:49.063	RRC/DCCH/rrcConnectionReconfiguration
16:12:49.063	RRC/DCCH/rrcConnectionReconfigurationC...
16:12:49.063	RRC/DCCH/rrcConnectionRelease
16:12:49.063	RR/BCCH/System Information Type 4
16:12:49.063	RR/BCCH/System Information Type 3
16:12:49.063	RR/BCCH/System Information Type 1
16:12:49.063	RR/BCCH/System Information Type 3
16:12:49.063	RR/Paging Response
16:12:50.038	RR/CCCH/Paging Request Type 1
16:12:50.089	RR/BCCH/System Information Type 4
16:12:50.108	RR/CCCH/Immediate Assignment
16:12:50.117	RR/DCCH/Paging Response
16:12:50.269	RR/SACCH/System Information Type 5
16:12:50.431	RR/DCCH/Classmark Change
16:12:50.432	RR/DCCH/GPRS Suspension Request
16:12:50.666	CC/Setup
16:12:50.676	CC/Call Confirmed
16:12:50.740	RR/SACCH/System Information Type 5
16:12:50.823	RR/SACCH/M Measurement Report
16:12:51.211	RR/SACCH/System Information Type 6

Vulnerability in CSFB



Vulnerability in CSFB



- The principle is like someone comes out from the door of LTE, then enters the door of GSM. He shouts, 'I must be as quick as possible!' Then he is permitted to enter, without the badge of GSM.

How can we exploit it?

- Basic idea
 - Because CSFB hasn't authentication procedure, attackers can send Paging Response on 2G network, impersonating the victim, then hijack the call link.

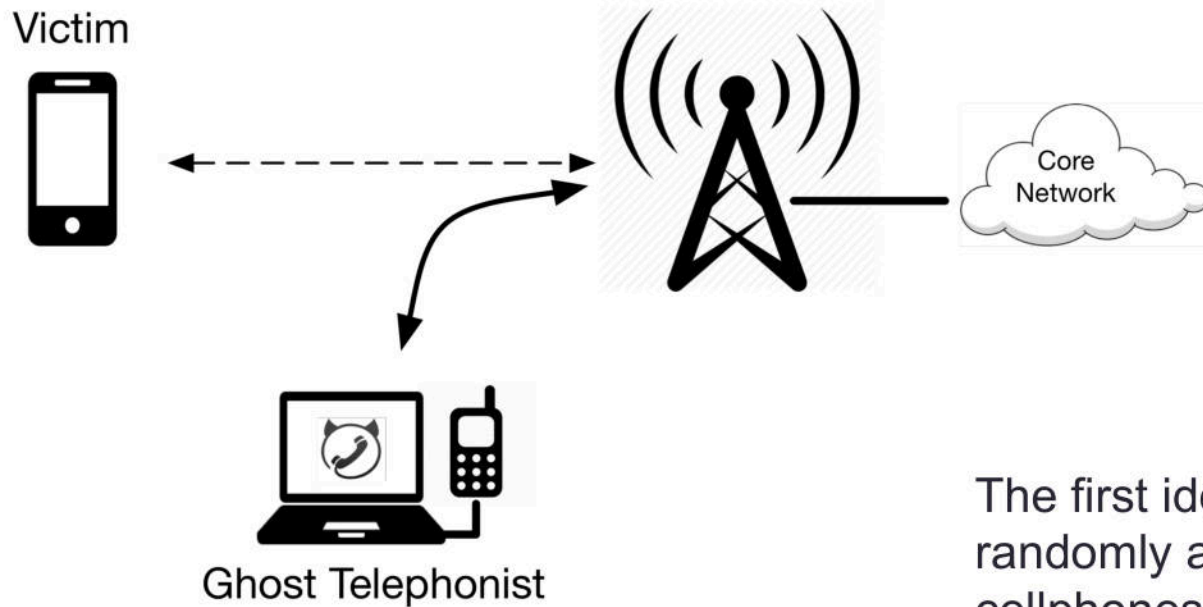
Experiment Environment



Demo Video 1



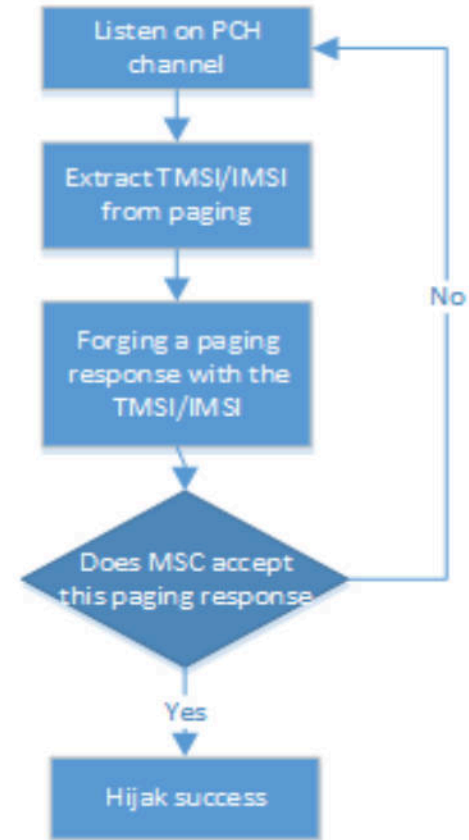
Exploitation I – Random Hijack



The first idea we got, is to randomly attack the cellphones in CSFB status.

Attack Steps

- 1) Listen on PCH channel
- 2) Extract TMSI/IMSI in paging
- 3) Forging a paging response with the TMSI/IMSI
- 4) Check whether MSC accepts the paging response



Why Network Sends Paging on 2G

- Cellphone stays in 4G
 - Network sends paging message in 4G LTE PCH. But this paging message uses 4G's S-TMSI, not 2G's TMSI.
 - S-TMSI and TMSI are generated during **combined** attach or location update procedure.
- C118 really hear paging messages
 - In some cases, network sends paging message both on 4G and 2G.
 - So using the TMSI captured on 2G can response the CSFB call on 4G.
 - Usually the network sends TMSIs, but sometimes it sends IMSI.

Hijack Result

- C118 has no SIM card.
- C118 successfully hijacked one call from 139*****920.

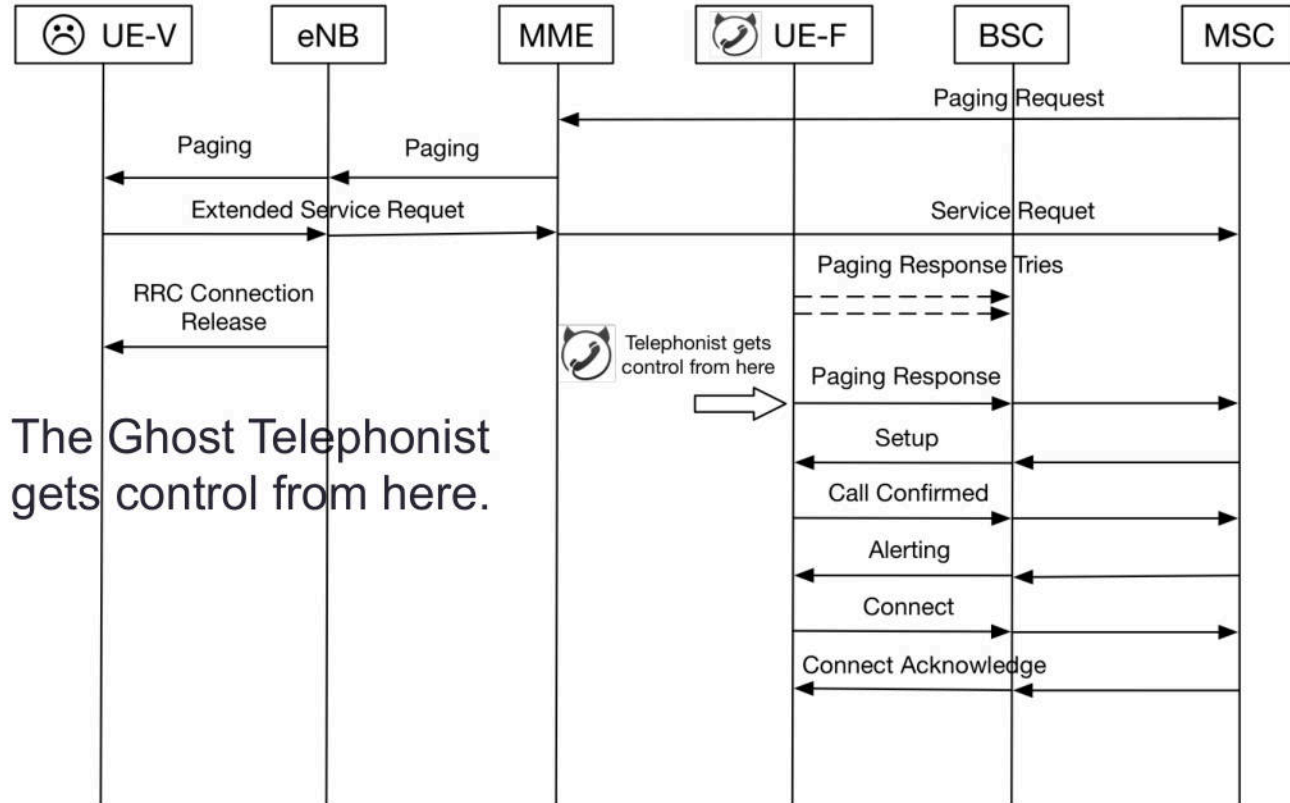
```
% (MS 1)
% No SIM, emergency calls are possible.

OsmocomBB#
% (MS 1)
% No SIM, emergency calls are possible.

% (MS 1)
% Incoming call (from 0-1390-8920)

% (MS 1)
% Call is connected
```


Attack Signaling Flow

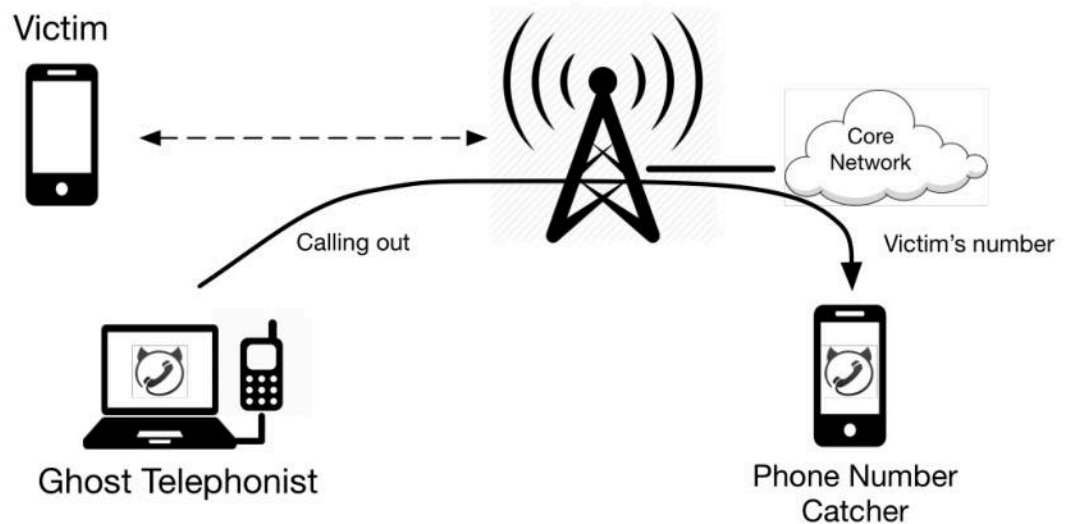


What can attacker do in further?

- If attacker answers the incoming call
 - The caller will recognize the callee's voice is abnormal.
- What does attacker know now
 - Victim's TMSI or IMSI
 - Caller's phone number
- What can attacker do in further?

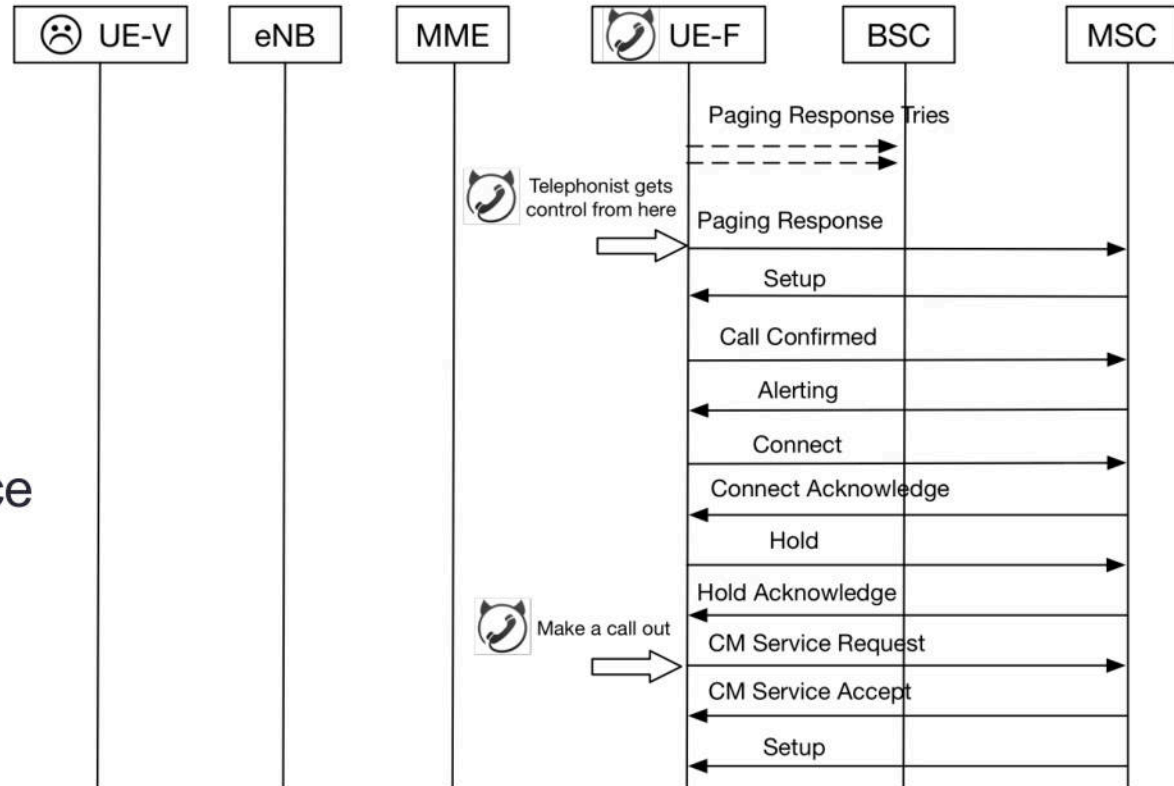
Exploitation II – Get Victim's Phone Number

- During an ongoing call, sending 'CM Service Request' does not trigger authentication, and the network will directly response a 'CM Service Accept'.
- So attacker can make a call to another in-hand phone to know the victim's ISDN number.



Attack Signaling Flow

- 1) Send 'hold'
- 2) Send 'CM Service Request'



PCAP Records

Here are the records captured by Wireshark on the laptop that Osmocom is running on.

It confirmed that attackers can build a MO call connection with the network.

LAPDm	81 U P, func=SABM(DTAP) (RR) Paging Response
LAPDm	81 I, N(R)=0, N(S)=0(DTAP) (CC) Setup
LAPDm	81 I, N(R)=1, N(S)=0(DTAP) (CC) Call Confirmed
LAPDm	81 I, N(R)=1, N(S)=1(DTAP) (CC) Alerting
LAPDm	81 I, N(R)=2, N(S)=2(DTAP) (CC) Connect
LAPDm	81 I, N(R)=1, N(S)=0(DTAP) (CC) Connect Acknowledge
LAPDm	81 I, N(R)=1, N(S)=1(DTAP) (CC) Hold
LAPDm	81 I, N(R)=2, N(S)=1(DTAP) (CC) Hold Acknowledge
LAPDm	81 I, N(R)=2, N(S)=2(DTAP) (MM) CM Service Request
LAPDm	81 I, N(R)=3, N(S)=2(DTAP) (MM) CM Service Accept
LAPDm	81 I, N(R)=3, N(S)=3(DTAP) (CC) Setup
LAPDm	81 I, N(R)=4, N(S)=3(DTAP) (CC) Call Proceeding
LAPDm	81 I, N(R)=4, N(S)=5(DTAP) (CC) Alerting
LAPDm	81 I, N(R)=4, N(S)=6(DTAP) (CC) Connect
LAPDm	81 I, N(R)=7, N(S)=4(DTAP) (CC) Connect Acknowledge
LAPDm	81 I, N(R)=5, N(S)=7(DTAP) (CC) Disconnect
LAPDm	81 I, N(R)=0, N(S)=5(DTAP) (CC) Release
LAPDm	81 I, N(R)=6, N(S)=0(DTAP) (CC) Release Complete
LAPDm	81 I, N(R)=0, N(S)=3(DTAP) (CC) Disconnect
LAPDm	81 I, N(R)=4, N(S)=0(DTAP) (CC) Release
LAPDm	81 I, N(R)=1, N(S)=4(DTAP) (CC) Release Complete
LAPDm	81 I, N(R)=1, N(S)=5(DTAP) (RR) Channel Release

Targeted Persistent Attack

- Former discussion is about randomly attack. Here we introduce targeted persistent attack to hijack the victim's link.
- Use TMSI
 - Once attacker knows one TMSI, he can persistently send Paging Response with this TMSI, no matter whether there is paging coming.
- Use IMSI
 - If attacker knows one victim's IMSI and know where he is, the attacker can go to the same paging area, and continuously send paging response with the IMSI to hijack the victim's link.
- Use ISDN number
 - If the attacker knows victim's phone number, the attacker can firstly call the victim then capture the TMSI of the victim. After that, use TMSI to launch the attack.

Targeted Persistent Attack – Use TMSI

- Condition
 - Attacker knows victim's TMSI
- Attack Steps
 - 1) Persistently sending Paging Response with this TMSI
 - 2) Once victim has a Paging procedure existing, attacker can quickly control the link.

Targeted Persistent Attack – Use IMSI

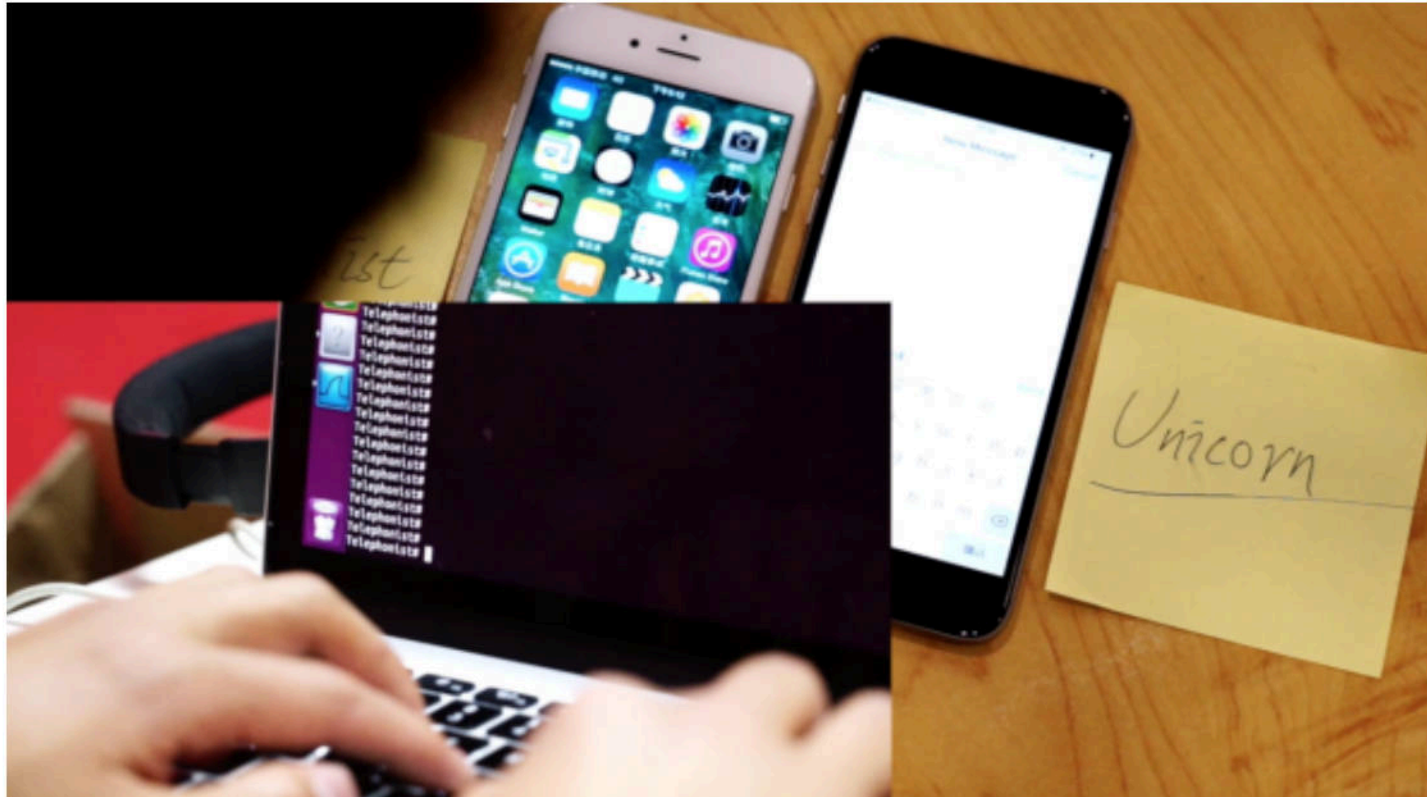
- Condition
 - Attacker knows victim's IMSI
- Attack Steps
 - 1) Persistently sending Paging Response with this IMSI
 - 2) Once victim has a Paging procedure existing, attacker can control the link.
- Disadvantage
 - When network side receives Paging Response with IMSI, it has to find out the corresponding TMSI, so this method will increase the link building latency then consequently results in low ratio of successful attack.

Targeted Persistent Attack – Use phone number

- Condition
 - Attacker knows victim's ISDN number
- Attack Steps
 - 1) Make a call to victim with an anonymous cellphone, to trigger a CSFB; Use one C118 to sniff TMSI
 - 2) Use another C118 to continuously send Paging Response with the TMSI and use anonymous cellphone to make second call to trigger CSFB again.
 - 3) Hijack and hold the victim's link.



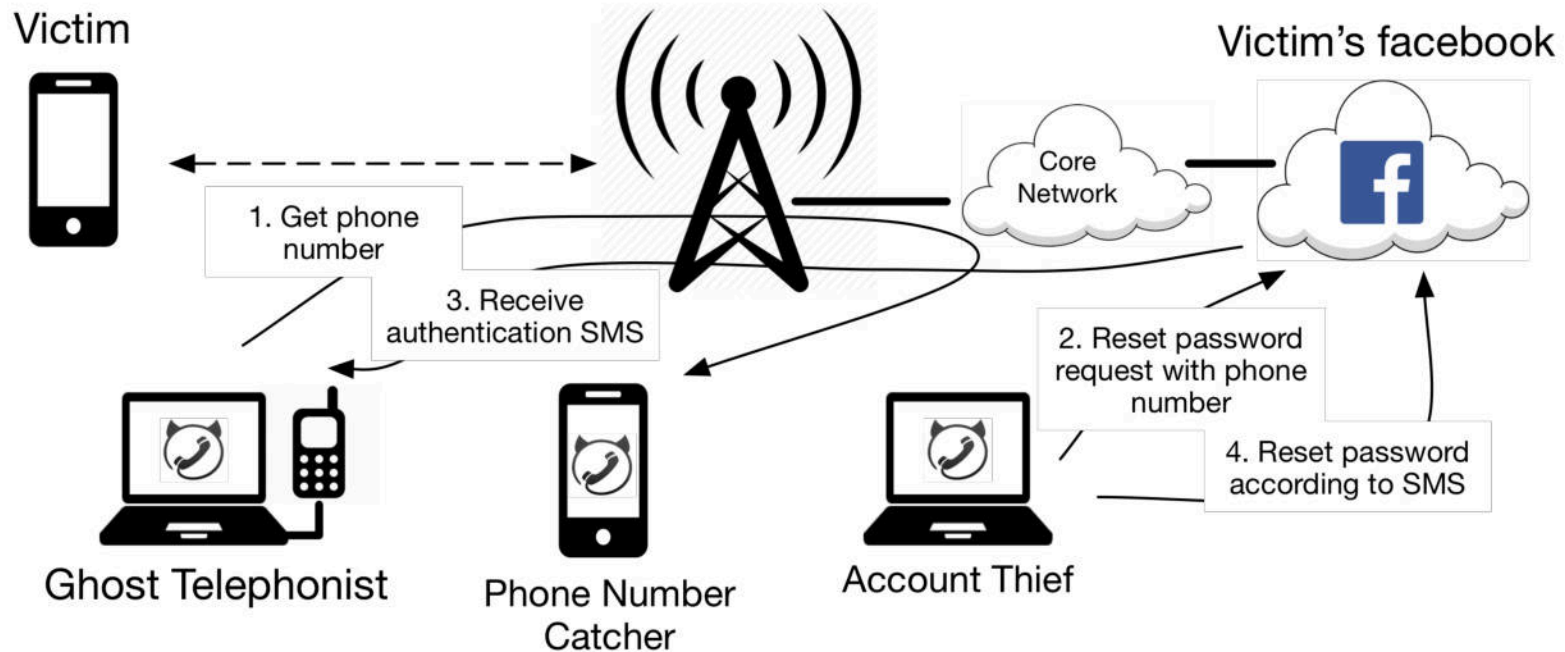
Demo Video 2



Advanced Exploitation – Attack Internet Account

- Login with verification SMS
 - Some applications permits login with cellphone number + verification SMS. Don't require inputting password.
- Reset login password with verification SMS
 - A lot of Internet application accounts use verification SMS to reset the login password. Attacker can use the cellphone number to start a password reset procedure then hijack the verification SMS.

Advanced Exploitation – Attack Internet Account



Advanced Exploitation – Attack Internet Account

- C118 Log shows it received the SMS sent from Facebook to the victim

Protocol	Length	Info
LAPDm	81	U P, func=SABM(DTAP) (RR) Paging Response
LAPDm	81	U F, func=UA(DTAP) (RR) Paging Response
LAPDm	81	I, N(R)=0, N(S)=0(DTAP) (CC) Setup
LAPDm	81	I, N(R)=1, N(S)=0(DTAP) (CC) Call Confirmed
LAPDm	81	I, N(R)=1, N(S)=1(DTAP) (CC) Alerting
LAPDm	81	I, N(R)=2, N(S)=2(DTAP) (CC) Connect
LAPDm	81	I, N(R)=1, N(S)=0(DTAP) (CC) Connect Acknowledge
LAPDm	81	I, N(R)=1, N(S)=1(DTAP) (CC) Hold
LAPDm	81	I, N(R)=2, N(S)=1(DTAP) (CC) Hold Acknowledge
LAPDm	81	I, N(R)=2, N(S)=2(DTAP) (MM) CM Service Request
LAPDm	81	I, N(R)=3, N(S)=2(DTAP) (MM) CM Service Accept
LAPDm	81	I, N(R)=3, N(S)=3(DTAP) (CC) Setup
LAPDm	81	I, N(R)=4, N(S)=3(DTAP) (CC) Call Proceeding
LAPDm/...	81	I, N(R)=4, N(S)=4(DTAP) (CC) Facility (GSM MAP) invoke notifySS
LAPDm	81	I, N(R)=4, N(S)=5(DTAP) (CC) Alerting
LAPDm	81	I, N(R)=4, N(S)=6(DTAP) (CC) Disconnect
LAPDm	81	I, N(R)=7, N(S)=4(DTAP) (CC) Release
LAPDm	81	I, N(R)=4, N(S)=7(DTAP) (CC) Connect
LAPDm	81	I, N(R)=0, N(S)=5(DTAP) (CC) Connect Acknowledge
LAPDm	81	I, N(R)=5, N(S)=0(DTAP) (CC) Release Complete
LAPDm	81	I, N(R)=0, N(S)=0 (Fragment)
LAPDm	81	I, N(R)=0, N(S)=1 (Fragment)
LAPDm	81	I, N(R)=0, N(S)=2 (Fragment)
LAPDm	81	I, N(R)=0, N(S)=3 (Fragment)
LAPDm	81	I, N(R)=0, N(S)=4 (Fragment)
LAPDm	81	I, N(R)=0, N(S)=5 (Fragment)
GSM SMS	81	I, N(R)=0, N(S)=6(DTAP) (SMS) CP-DATA (RP) RP-DATA (Network to MS)
LAPDm	81	I, N(R)=7, N(S)=0(DTAP) (SMS) CP-ACK
LAPDm	81	I, N(R)=7, N(S)=1(DTAP) (SMS) CP-DATA (RP) RP-ACK (MS to Network)
LAPDm	81	I, N(R)=2, N(S)=7(DTAP) (SMS) CP-ACK
LAPDm	81	I, N(R)=6, N(S)=1(DTAP) (CC) Disconnect
LAPDm	81	I, N(R)=2, N(S)=6(DTAP) (CC) Release
LAPDm	81	I, N(R)=7, N(S)=2(DTAP) (CC) Release Complete
LAPDm	81	I, N(R)=7, N(S)=3(DTAP) (RR) Channel Release

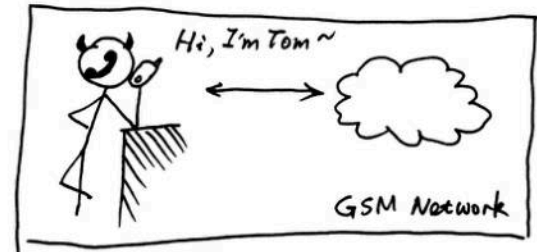
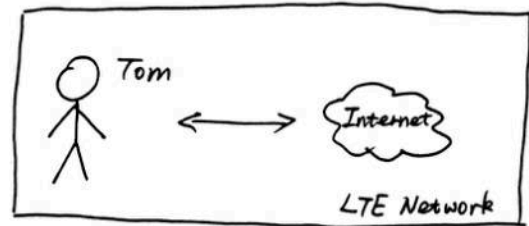
Advanced Exploitation – Attack Internet Account

- We investigated the password reset routine of many popular websites and applications, including global and Chinese ones, for example SNS website, payment website, and IM App etc.

Website/App	SMS sending direction
Facebook	Internet → cellphone
Google account	Internet → cellphone
WhatsApp	Internet → cellphone
Alipay (Chinese PayPal)	Internet → cellphone
WeChat (Chinese WhatsApp)	Cellphone → Internet
DiDi (Chinese Uber)	Internet → cellphone
Sina Weibo (Chinese Twitter)	Cellphone → Internet

Constraints

- Telephonist and the victim should be in the same paging area (several base stations' coverage)
 - The attack is feasible only when 2G network is in use and uses A5/1 or A5/0 encryption.
-
- Telephonist attack doesn't need to access SS7 core network.
 - Telephonist attack doesn't need fake base station.
 - The victim keeps online in 4G network and is not aware of the attack.



Different Behaviors from Different Terminals

- Different behaviors
 - We found some cellphones are easily hijacked but some are not.

Victim Cellphone	Chipset	Chipset Vendor	Fake Callee
Xiaomi Mi4c	msm8992	Qualcomm	✓
Nubia Z9 max	msm8994	Qualcomm	✓
iPhone 5s	mdm9615m	Qualcomm	✓*
iPhone 6	mdm9625m	Qualcomm	✓*
iPhone 6s	mdm9635m	Qualcomm	✓
Qiku	mt6753	MTK	✓*
Huawei P9	kirin960	Hisilicon	✓*

[*] in this table means jamming is needed in the attack.

Cellphones with [*] have better defense against this attack. Jamming is needed to cut off the connection between victim cellphones and the network.

Failure Analysis

- What 'successful hijack' means
 - After the attacker sends Paging Response, he receives the call. This means a successful hijack.
- Whether can hold the link
 - When the attacker receives the call, the call may be interrupted after a short time.
 - The reason is: the victim cellphone didn't receive the call and it wants to 'Fast Return' back to 4G, so it will launch a Location Area Update procedure in 2G. This LAU results in the break of attacker's link.

Fast Return Case 1 – Mi4C Cellphone, Qualcomm Chipset

```
PCCH / Paging
PCCH / Paging
LTE NAS EMM Plain OTA Outgoing Message
UL_CCCH / RRCConnectionRequest
DL_CCCH / RRCConnectionSetup
UL_DCCH / RRCConnectionSetupComplete
DL_DCCH / SecurityModeCommand
UL_DCCH / SecurityModeComplete
DL_DCCH / RRCConnectionReconfiguration
UL_DCCH / RRCConnectionReconfigurationComplete
DL_DCCH / RRCConnectionRelease
RR/Paging Response
RR/Paging Response
MM/Location Updating Request
LTE NAS EMM Plain OTA Outgoing Message
UL_CCCH / RRCConnectionRequest
DL_CCCH / RRCConnectionSetup
UL_DCCH / RRCConnectionSetupComplete
DL_DCCH / DLInformationTransfer
LTE NAS EMM Plain OTA Incoming Message
LTE NAS EMM Plain OTA Outgoing Message
UL_DCCH / ULInformationTransfer
DL_DCCH / RRCConnectionRelease
Radio Bearer ID: 0, Freq: 39148, SFN: 224
Radio Bearer ID: 0, Freq: 39148, SFN: 352
Extended service request Msg
Radio Bearer ID: 0, Freq: 39148, SFN: 0
Radio Bearer ID: 0, Freq: 39148, SFN: 359
Radio Bearer ID: 1, Freq: 39148, SFN: 0
Radio Bearer ID: 1, Freq: 39148, SFN: 362
Radio Bearer ID: 1, Freq: 39148, SFN: 0
Radio Bearer ID: 1, Freq: 39148, SFN: 364
Radio Bearer ID: 1, Freq: 39148, SFN: 0
Radio Bearer ID: 1, Freq: 39148, SFN: 371
Direction : MS To NetworkLength: 13
Length: 0022
Direction : MS To NetworkLength: 15
Tracking area update request Msg
Radio Bearer ID: 0, Freq: 39148, SFN: 0
Radio Bearer ID: 0, Freq: 39148, SFN: 766
Radio Bearer ID: 1, Freq: 39148, SFN: 0
Radio Bearer ID: 1, Freq: 39148, SFN: 770
Tracking area update accept Msg
Tracking area update complete Msg
Radio Bearer ID: 1, Freq: 39148, SFN: 0
Radio Bearer ID: 1, Freq: 39148, SFN: 774
```

Paging Response failure

Location Update not completed

Fast Return Case 2 – Qiku Cellphone, MTK Chipset

```
[NW->MS] ERRC_DLInformationTransfer
[NW->MS] EMM_CS_Service_Notification(paging identity="TMSI_PAGING_TYPE")
[MS->NW] EMM_Extended_Service_Request(service type="MT_CSFB", CSFB response="CSFB_ACCEPTED_BY_UE")
[MS->NW] ERRC_ULInformationTransfer
[NW->MS] ERRC_RRConnectionRelease(cause:[ReleaseCause_other], redirectInfo:[1])
[MS->NW] RR_PAGING_RESPONSE
[NW->MS] RR_CHANNEL_RELEASE
[MS->NW] MM_LOCATION_UPDATING_REQUEST (LU type: MM_NORMAL_LU)
[NW->MS] MM_LOCATION_UPDATING_ACCEPT
[MS->NW] ERRC_RRConnectionRequest
[NW->MS] ERRC_RRConnectionSetup
[MS->NW] EMM_Tracking_Area_Update_Request(EPS update type="EMM_UPDATE_TYPE_COMBINED_TAU_IMSI_ATTACH", active flag="KAL_FALSE")
[MS->NW] ERRC_RRConnectionSetupComplete
[NW->MS] ERRC_DLInformationTransfer
[NW->MS] EMM_Authentication_Request
[MS->NW] EMM_Authentication_Response
[MS->NW] ERRC_ULInformationTransfer
[NW->MS] ERRC_DLInformationTransfer
[NW->MS] EMM_Security_Mode_Command(integrity algorithm="INT_128_EIA2", ciphering algorithm="ENC_EEA0")
[MS->NW] EMM_Security_Mode_Complete
[NW->MS] ERRC_ULInformationTransfer
[NW->MS] ERRC_RRConnectionReconfiguration(measCfg:[0],mobCtrlInfo:[0],dedInfoNASList:[1],radioresCfgDed:[1],secCfgHO:[0])
[MS->NW] ERRC_RRConnectionReconfigurationComplete
[NW->MS] EMM_Tracking_Area_Update_Accept(EPS update result="EMM_UPDATE_RESULT_COMBINED_UPDATED")
[MS->NW] EMM_Tracking_Area_Update_Complete
[MS->NW] ERRC_ULInformationTransfer
```

Paging Response failure

Location Update completed

Jamming on the Victim

- Break victim's LAU
 - If the attacker sends jamming signal to the victim, this will break the link between victim and network, so that the attacker can keep holding the fake link.
 - This will increase the success ratio of the attack.
 - Disadvantage is the victim may sense the attack.

Countermeasures

- To operators
 - Improve the CSFB authentication procedure. The additional latency is acceptable.
 - Speed up VoLTE service deployment
- To Internet service provider
 - Be careful that the PSTN authentication is not safe. NIST guidance suggests not to use PSTN in two-factor authentication.
 - The password reset procedure should be improved by additional personal information check.

GSMA CVD Program

- What's CVD Program?
 - CVD, Coordinated Vulnerability Disclosure Programme
 - 'Disclosures to GSMA must focus on **open standards** based technologies which are **not proprietary to a specific vendor** but that are used across, or have significant impact on, the mobile industry (e.g. including but not limited to protocols specified by IETF, ITU, ISO, ETSI, 3GPP, GSMA etc.)'

Good platform for reporting standard based vulnerability.



GSMA CVD Program

- UnicornTeam received the **FIRST** acknowledgement on the Mobile Security Research Hall of Fame.
- GSMA transferred the vulnerability information to every operators.
- Now related operators are fixing or already fixed this vulnerability.

Mobile Security Research Hall of Fame

Welcome to the GSMA Mobile Security Research Hall of Fame.

The GSMA's Mobile Security Research Hall of Fame lists security vulnerability finders that have made contributions to increasing the security of the mobile industry by submitting disclosures to the GSMA or its members. It is the primary mechanism for the GSMA to recognise and acknowledge the positive impact the finder has had on the mobile industry by following the GSMA's CVD process.

The Hall of Fame also facilitates the nomination and recognition of other finders that may have made significant discoveries of vulnerabilities to individual GSMA member companies.

Entry to the Mobile Security Research Hall of Fame is purely optional and is at the discretion of the finder, the GSMA and/or the nominating GSMA member.

On behalf of the mobile industry, we would like to thank the following people for making a responsible disclosure to us and recognise their contribution to increasing the security of the mobile industry:

Date	Name	Organisation	Link
23/2/2017	Yuwei Zheng, Lin Huang, Haoqi Shan, Jun Li, Qing Yang	Unicorn Team, Radio Security Research Dept., 360 Technology	http://unicorn.360.com

Thank You ~